

Cyber Tabletop Exercise

Cloud Storage Misconfiguration and Customer Document Exposure

Exercise type: Facilitated tabletop exercise

Scenario source: Structured STIX scenario transformed into a facilitation-ready TTX

Sector: Financial services

Primary business area: Digital onboarding and mortgage workflows

Duration: 90 minutes

Audience: Executive, operational, technical, legal/compliance, communications

1. Introduction

This tabletop exercise simulates a cloud storage misconfiguration that exposes sensitive customer onboarding and mortgage documentation to the public internet. The scenario is designed to test how the organization detects, contains, scopes, escalates, communicates, and remediates a data exposure event involving regulated customer information.

The exercise assumes that customer files stored in a cloud-hosted document repository became reachable without authentication because of an unintended permission change. Initial notification comes from an external security researcher rather than internal controls, creating immediate pressure around validation, exposure scoping, legal analysis, regulator engagement, and customer communications.

2. Exercise Objectives

By the end of the exercise, participants should be able to:

1. Validate and classify a suspected public cloud data exposure affecting sensitive banking records.
 2. Execute early containment actions while preserving evidence and maintaining decision logs.
 3. Assess exposure scope, including affected populations, data types, exposure duration, and evidence of access.
 4. Coordinate decisions across cyber, cloud operations, business owners, legal, privacy, compliance, fraud, communications, and executive leadership.
 5. Determine notification thresholds and timing for regulators, customers, partners, and internal stakeholders.
 6. Evaluate business continuity impacts on digital onboarding and mortgage operations.
 7. Identify medium- and long-term control improvements for cloud governance and sensitive data protection.
-

3. Scope

In scope

- Cloud storage used for digital onboarding and mortgage document handling
- Customer identity documents, onboarding files, and mortgage application artifacts
- Cyber incident response and cloud containment
- Regulatory, privacy, legal, and reputational decision-making
- Internal and external communications
- Recovery and control uplift planning

Out of scope

- Full forensic reconstruction of every cloud event
 - Detailed regulator-specific legal advice
 - Live technical testing against production systems
-

4. Participant Roles

Executive / crisis leadership

- Crisis lead / executive sponsor
- Business line leadership for digital banking and lending
- Chief Information Security Officer or delegate

Operational / control functions

- Security Operations Center (SOC)
- Incident response lead
- Cloud platform / infrastructure team
- Application owner for onboarding and mortgage workflows
- Privacy office / data protection lead
- Legal counsel
- Compliance / regulatory affairs
- Fraud / customer risk
- Corporate communications / public affairs
- Customer contact center leadership

Technical participants

- Cloud security engineering
 - Identity and access management
 - Logging / SIEM team
 - Digital platform engineering
 - Data governance / records management
-

5. Rules of Engagement

- This is a no-fault learning exercise intended to improve readiness.
 - Real-world incidents take priority.
 - Participants should respond according to current roles, responsibilities, and available processes.
 - Reasonable assumptions may be made where information is incomplete.
 - The scenario is fictionalized but should be treated as realistic.
 - The purpose is to identify strengths, gaps, decision friction, and improvement opportunities.
-

6. Scenario Overview

The organization operates cloud-hosted digital onboarding and mortgage workflows. A cloud document storage repository contains onboarding forms, scanned identity documents, proof-of-address records, income documentation, and mortgage application artifacts.

Due to a permissions misconfiguration, parts of this storage location become publicly accessible from the internet without authentication. The issue is not identified internally. Instead, an external security researcher reports that customer mortgage and onboarding documents are reachable through a public URL path.

The organization must rapidly determine whether the report is valid, whether public access is ongoing, what data was exposed, how long the exposure existed, whether any third parties accessed or downloaded the documents, and what notification obligations may apply.

7. Assumptions for the Exercise

- The exposed storage location is production, not a test environment.
 - Documents may include personally identifiable information and financial application records.
 - Cloud logs exist, but retention and completeness are uncertain.
 - The organization has incident response, crisis escalation, privacy, and communications processes, but cloud-specific decision playbooks are uneven.
 - No ransomware or destructive activity is observed; this is a confidentiality and governance incident.
-

8. Suggested Exercise Flow

- 10 min: Introduction, objectives, roles, rules
 - 15 min: Inject 1 discussion
 - 20 min: Inject 2 discussion
 - 20 min: Inject 3 discussion
 - 10 min: Inject 4 discussion
 - 15 min: Final debrief and lessons learned
-

9. Exercise Narrative and Injects

Inject 1 — External Researcher Disclosure

Exercise time: 09:00

A security researcher contacts the bank's security mailbox and states that customer mortgage and onboarding documents are accessible from a public URL path without authentication. The researcher shares several redacted examples and requests confirmation that the issue is being handled responsibly.

What participants know

- The report appears credible.
- The documents appear to belong to real customers.
- The exposed platform is associated with cloud document storage used by digital banking workflows.
- There is no immediate evidence yet of malicious exploitation.

Key discussion prompts

- How is the report validated and triaged?
- Who owns containment authority for public cloud exposure?
- What immediate actions are taken to revoke access without destroying evidence?
- Which stakeholders must be engaged in the first hour?
- How is chain of custody established for screenshots, URLs, and logs?
- Who approves outreach back to the researcher?

Expected actions

- Open a high-priority security incident.
- Validate exposure using approved internal processes.
- Disable public access or apply compensating controls.
- Preserve logs, metadata, access policies, object listings, and timestamps.
- Notify incident response, cloud engineering, privacy, legal, compliance, and business owners.
- Create a decision log and assign an incident commander.

Facilitator notes

Push participants to address a common tension: immediate lockdown versus evidence preservation. Probe whether they know which team can change cloud permissions quickly and whether approvals are clear after hours.

Inject 2 — Scope and Notification Dilemma

Exercise time: 11:00

Initial cloud review confirms that unauthenticated internet access was possible. The exposed repository contains onboarding documents, ID images, and mortgage application artifacts. Logging is incomplete: object-level access logging was enabled only recently, while platform-level logs go back further. The organization now must determine exposure duration, affected customer count, evidence of access, and whether immediate regulator and customer notification is required.

What participants know

- The exposure is real.
- Sensitive customer records were stored in the affected repository.
- The exact start date of the misconfiguration is unknown.
- Logs may not fully show every access event.
- Customer documents include high-risk identity and financial information.

Key discussion prompts

- How do you estimate the exposure window if logs are incomplete?
- What data classes are present, and how does that affect notification thresholds?
- What is the minimum evidentiary standard for deciding whether a reportable breach occurred?
- Who determines regulator notification timing?
- What should be communicated internally before facts are fully established?
- Do you suspend onboarding or mortgage intake workflows pending validation?

Expected actions

- Begin exposure scoping using configuration history, backups, snapshots, change tickets, and cloud audit trails.
- Inventory affected objects and data categories.
- Estimate customer impact bands (confirmed, probable, possible).
- Engage privacy/legal/compliance to assess reporting triggers.
- Prepare draft internal leadership update and external holding statements.
- Evaluate fraud monitoring and identity-theft support measures.

Facilitator notes

Probe how the team acts under uncertainty. Good responses distinguish between confirmed facts, bounded assumptions, and decisions that cannot wait for perfect evidence.

Inject 3 — External Interest and Operational Pressure

Exercise time: 14:00

A journalist contacts corporate communications, stating they received a tip that a bank cloud repository exposed customer mortgage records. At the same time, business leadership asks whether digital onboarding can continue safely, and the fraud team requests a list of potentially affected customers for enhanced monitoring. Social media monitoring shows early speculation but no leaked files have appeared publicly.

What participants know

- Media awareness may be emerging.
- Customer harm has not yet been confirmed, but the risk is credible.
- Business leaders need a decision on continuing cloud-dependent workflows.
- Customer support teams may soon receive inbound questions.

Key discussion prompts

- What is the communications strategy before public confirmation?
- What message goes to employees, customer-facing teams, and executives?
- Do you continue, restrict, or temporarily pause certain onboarding and mortgage processes?
- How do fraud, privacy, legal, and communications coordinate customer-protection measures?
- What evidence threshold triggers proactive customer notification?

Expected actions

- Finalize a coordinated communications posture.
- Establish customer-service scripts and escalation paths.
- Decide whether to continue operations with compensating controls.
- Initiate fraud watchlists and identity-protection planning.
- Identify board or executive committee notification thresholds.

Facilitator notes

Look for coordination breakdowns between legal caution, business urgency, and communications timelines. Ask who is empowered to approve customer-facing statements.

Inject 4 — Containment Complete, Governance Questions Remain

Exercise time: Next business day, 10:00

The cloud team confirms public access has been removed. Preliminary review suggests the issue resulted from a permissions error introduced during a storage configuration change. There is still no conclusive evidence of mass download, but the organization cannot rule out third-party access during the exposure period. Leadership requests a formal incident summary, notification recommendation, and control-improvement plan.

What participants know

- Active exposure is contained.
- Root cause points to cloud configuration weakness rather than malware.
- There is residual uncertainty about whether files were accessed.
- Control failures may include change management, cloud posture monitoring, logging, and data governance.

Key discussion prompts

- What should the final executive recommendation include?
- How do you document residual uncertainty for regulators and customers?
- What corrective actions are mandatory in the next 30, 60, and 90 days?
- How will the organization validate that similar exposures do not exist elsewhere?

Expected actions

- Produce an incident summary with facts, assumptions, impacts, decisions, and open items.
- Decide on regulator/customer notification path and timing.
- Launch broader cloud exposure review across sensitive repositories.
- Define control uplift plan: guardrails, approvals, logging, scanning, asset inventory, and monitoring.
- Schedule after-action review and ownership tracking.

Facilitator notes

Encourage specificity. Strong teams move beyond “improve monitoring” and define concrete owners, timeframes, and measurable control outcomes.

10. Decision Points

1. **Incident classification:** Is this a security event, a privacy incident, a reportable breach, or all three?
 2. **Containment timing:** Do you lock down access immediately before full evidence preservation is complete?
 3. **Business continuity:** Do you pause onboarding and mortgage document intake?
 4. **Notification threshold:** When do you notify regulators and affected customers under incomplete facts?
 5. **Public communications:** Do you issue a holding statement before public confirmation?
 6. **Enterprise response:** Do you initiate a wider cloud posture review across other repositories?
-

11. Technical Impacts to Explore

- Public exposure of customer ID and mortgage records
 - Incomplete or delayed cloud access logging
 - Uncertainty in exposure duration and access counts
 - Weaknesses in storage permission governance
 - Potential gaps in data classification and retention controls
 - Possible need for rapid enterprise-wide cloud configuration review
-

12. Business Impacts to Explore

- Customer trust erosion

- Regulatory scrutiny and reporting burden
 - Increased fraud and identity-theft risk
 - Call center surge and complaint handling
 - Delays in onboarding and mortgage processing
 - Brand and reputational pressure if media coverage escalates
 - Senior leadership and board reporting demands
-

13. Facilitator Reference: Strong Response Indicators

A mature response usually includes:

- Rapid verification and containment authority
- Clear incident command structure
- Strong evidence preservation discipline
- Cross-functional triage among cyber, cloud, privacy, legal, compliance, and business teams
- Decision-making under uncertainty with documented rationale
- Early fraud-prevention and customer-protection planning
- Broader control review beyond the single affected storage location

Potential weaknesses to watch for:

- Delayed containment due to ownership ambiguity
 - Overconfidence despite incomplete logging
 - Poor linkage between security and privacy/regulatory workflows
 - No clear communication plan for employees or customers
 - Failure to look for similar exposures elsewhere
-

14. Debrief Questions

- What went well in the first hour?
 - Where did decision ownership become unclear?
 - Were containment and evidence preservation balanced effectively?
 - How confident are we in our ability to determine exposure scope?
 - Are our regulator and customer notification processes usable under time pressure?
 - What cloud governance controls would have prevented or detected this scenario earlier?
 - What capabilities need investment in the next quarter?
-

15. Improvement Planning Template

Immediate actions (0–7 days)

- Confirm containment and preserve evidence
- Complete impact scoping and legal/privacy assessment

- Stand up fraud monitoring and customer support preparations
- Issue executive summary and incident timeline

Near-term actions (30 days)

- Review public access settings across sensitive cloud storage
- Validate logging retention and object access visibility
- Tighten approval workflow for permission changes
- Update cloud incident response playbooks

Medium-term actions (60–90 days)

- Implement preventive cloud guardrails and policy checks
- Improve asset inventory and data classification coverage
- Expand continuous posture monitoring for exposed storage
- Run a repeat tabletop or technical simulation to validate improvements

16. Optional Exercise Artifacts

Facilitators may choose to prepare:

- Sample researcher email
- Screenshot of public URL path
- Draft executive situation report
- Draft regulator notification decision memo
- Draft customer Q&A / contact center script
- Draft media holding statement

17. MITRE ATT&CK Mapping

This scenario is primarily a **misconfiguration-driven data exposure** rather than a classic multi-stage intrusion. The mapping below reflects behaviors and control themes relevant to the scenario narrative.

Relevant ATT&CK tactics

- **TA0009 – Collection**
- **TA0010 – Exfiltration**
- **TA0007 – Discovery**
- **TA0005 – Defense Evasion** (limited relevance where logging or visibility gaps hinder detection)

Relevant ATT&CK techniques

- **T1530 – Data from Cloud Storage Object**
Sensitive documents are accessible from cloud object storage.

- **T1083 – File and Directory Discovery**

An external party can enumerate or locate accessible document paths and contents.

- **T1020 – Automated Exfiltration** (*scenario-adjacent risk*)

If a malicious actor scripted bulk retrieval of exposed files, this technique would be relevant.

- **T1567 – Exfiltration Over Web Service** (*scenario-adjacent risk*)

Public internet retrieval of exposed cloud-hosted objects aligns with web-based exfiltration patterns.

Defensive observations

- Preventive controls align strongly with cloud configuration management, logging, asset inventory, data classification, and exposure monitoring.
 - The scenario also maps operationally to data breach response, privacy incident management, and cloud governance maturity.
-

18. Source-to-Scenario Traceability

This exercise is derived from structured scenario data indicating:

- A banking organization running cloud-hosted onboarding and mortgage workflows
 - Cloud document storage containing onboarding documents, ID images, and mortgage artifacts
 - A cloud storage misconfiguration creating unauthenticated public access
 - An initial researcher disclosure inject
 - A follow-on inject focused on scoping, access evidence, and notification decisions
 - Courses of action centered on immediate lockdown, logging review, and cloud guardrails
-

19. Suggested Title for Distribution

Cloud Misconfiguration Exposing KYC and Mortgage Documents — Cyber Tabletop Exercise